PRAMAAN प्रमाण

Proof, not a verdict. Face liveness and presentation-attack detection for the MOSIP Registration Client

MOSIP Decode 2026 · Problem Statement 04 · Team: Bhavya Garg · Code (MPL-2.0): github.com/GargBhavya-tech/pramaan

1. The problem

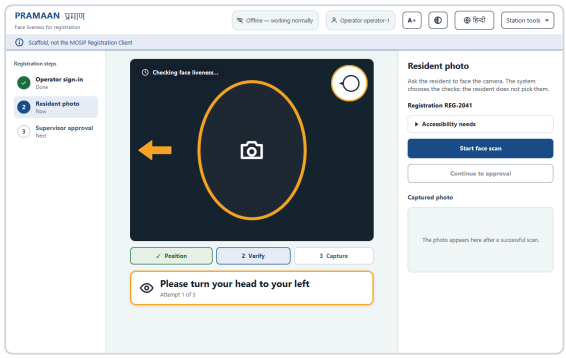
A resident's face is captured through a certified SBI device. Liveness is judged on the device's live **preview stream**, but the photo that gets stored is the device's **signed capture**, and **nothing links the two**. Whoever controls the preview can pass liveness with one face and have another enrolled. On **Android** the client never sees preview frames at all. **Injected video** (a virtual camera such as OBS, a deepfake pipeline) is outside ISO/IEC 30107, which covers presentation attacks only. A corrupt operator can log in with a photo of a supervisor. And a pass/fail made on the client cannot be re-checked by the server later, or re-scored when better models exist.

2. Our solution

PRAMAAN defines the two interfaces the problem statement asks for: **FaceFrameSource** (frames *and* the signed capture from the same object, which is what makes binding possible) and **LivenessEngine** (frames in; states, guidance and a decision out, never a score to the screen). The same Java engine runs on desktop inside the client (Mode C) and on Android inside the SBI device app as a library (Mode D). Before it accepts a face it answers seven questions in order: is the stream from a real sensor, is there one usable face, does it look alive without asking anything, does it carry the marks of an attack instrument, what do all the cues say together (accept, challenge or reject), did a live person answer a challenge nobody could have predicted, and is the stored face provably the one that passed.

1	2	3	4	5	6	7
Real sensor? source integrity	One usable face quality gate	Looks alive? passive, no asking	Attack marks? print, screen, flat	Fusion accept / challenge / reject	Live answer? random challenge	Same face? binding + signed evidence

- **Capture binding.** Four locks before any accept: the session nonce echoed inside the device-signed capture, a hash chain over the frames, identity continuity, and time. They work on **unmodified SBI**; each swap attack is a test.
- **Evidence, not a verdict.** A signed JWS in the face BIR `others` map (the bdb is untouched). A server can re-verify it with one command, or re-score stored crops with a newer model. A transparency log (Merkle, matching the Certificate Transparency test vectors) makes omission detectable.
- **Cues that fail differently**, fused with per-cue abstention: passive model, moiré, flash reflection (a random colour code, 20.7 bits), scene and light consistency, stereo depth. Each switches on only if the station has what it needs; otherwise it abstains and is never evidence for a spoof.



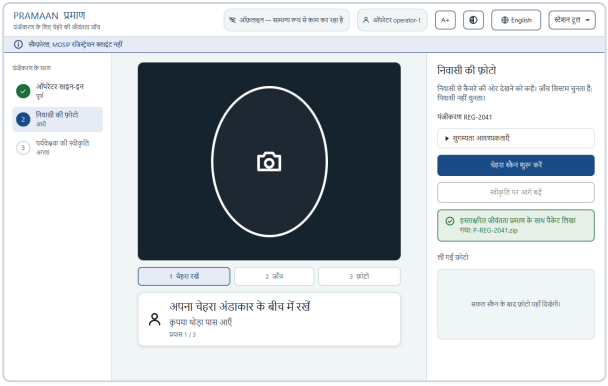
The station screen, rendered from the real code (no live camera). One plain sentence and an icon; no score, no cause.

- **Injection defence.** Device identity, the OS camera registrations (DirectShow, so OBS is seen), and a JPEG stream fingerprint.
- **Inclusion by design.** Blink, pulse and pupil reflex only ever vote *for* life, because elderly, disabled and darker-skinned residents fail them for innocent reasons. Hindi, icons, text-to-speech, accessibility profiles, an infant mode, a dual-controlled exception flow.
- **Insider fraud.** A resident capture that matches the logged-in operator's face is blocked; per-operator z-scores against the centre's own baseline.
- **An SBI Liveness Profile proposal** (signed preview, a signed log of what the device's light showed, a signed burst), with a runnable reference device.
- **It attacks itself.** Red-team fuzzers searched our own cues and found two real weaknesses (below), which are logged rather than hidden.

3. Usability

The operator sees a step rail (sign-in, resident photo, supervisor approval), plain-language messages and one task at a time; the resident sees one sentence and an icon. Quality problems get guidance ("Please improve the lighting") and do not use up an attempt; security problems get a generic message that reveals nothing an attacker could adapt

to. Larger-text and high-contrast modes, 44 px targets, visible focus, Hindi on every screen. Every status has an icon and a word, never colour alone.



The same screen in Hindi (complete Devanagari translation, verified by a native Hindi speaker), with larger-text and high-contrast modes in the header.

4. Impact for MOSIP

- Deployable on today's SBI: no spec change is needed for the capture-swap lock; JavaFX 11 matches the Registration Client; the engine fails closed.
- Includes a non-invasive patch for MOSIP's `registration-client` (4 ServiceLoader hooks) plus a standalone JavaFX evaluation scaffold.
- Removes a class of attack (preview/capture swap, injected video) and an audit gap (no re-checkable evidence), without locking out the residents MOSIP most wants to reach.
- MPL-2.0, like MOSIP's repositories; every dependency and model has a licence row, and two open licence questions are listed for MOSIP rather than assumed away.

5. Engineering Verification & ISO/IEC 30107-3 Alignment

Scientific discipline. In biometric evaluation, claiming laboratory accuracy without statistical confidence intervals is misleading. PRAMAAN implements the full ISO/IEC 30107-3 evaluation framework with Clopper-Pearson exact confidence bounds, ready for population-scale field calibration.

Tested and measured
738 automated tests pass (0 failures across strict Linux and Windows CI environments)
Hardware Measured: Models & camera timed on physical Android phone; OBS virtual camera veto shown on Windows webcam list
Flash code: 6 colours × 8 steps = 1,679,616 sequences = **20.7 bits** (≤ 3 changes/s, WCAG 2.3.1 compliant)
Insider threat analytics: 6 failures in 40 at a 2% baseline gives z ≈ 5.87; operator self-enrollment blocked
Transparency log matches CT test vectors; capture-swap negative tests pass; fails closed

Scope & Responsible Disclosure
Provisional Thresholds: Operating points in `config/operating-points.json` are provisional until calibrated on site-specific field corpora
Scaffold vs Client: Client patch provided for MOSIP client; standalone scaffold provided for evaluator testing; certified SBI hardware testing planned
Android Replay Limit: Passive model fooled by screen replays (0.98 score) and flash needs ≥ 3 fps (phone got 2.7–2.9 fps); replay defence on Android rests on challenge alone
Red-team Findings: Automated fuzzer discovered moiré frequency blind spots (R-01); mitigated by requiring active flash/stereo confirmation (R-03)

6. Next

(1) Widen the flash experiment: separated live from replay in author's test on laptop & phone (moving 0.1 to 0.15 with brightness and distance); unmeasured on a multi-person corpus. (2) A consented corpus and the calibrator that is already written, so every threshold comes from data. (3) A real device, a second camera, a phone. (4) Ask MOSIP how an SBI extension should be proposed, and settle two model licences.

Every claim, its number and its reproduction command: **docs/claim-sheet.md**. Design with the reasoning and the maths: **docs/PRAMAAN_Final_Bible.md** (Parts 0-48). Built with an AI coding assistant under the author's direction.